CyberRiskGuardian en classe

Guide de l'enseignant — Ensemble pédagogique 2.1.2

Marc-André Léger, Ph. D.

novembre 2026

Table des matières

1 À propos de ce guide 2

1.1 Contenu de l'ensemble 2

1.2 Qui peut l'utiliser, et quand une licence est nécessaire 3

2 CyberRiskGuardian en une page 3

3 Résultats d'apprentissage 4

4 Choisir un parcours d'outil 5

4.1 Configuration minimale par parcours 6

4.2 La vérification que chaque étudiant fait en premier 7

5 Utiliser le manuel 8

6 Modèles d'intégration 9

6.1 Modèle 1 — Un atelier (3 heures) 9

6.2 Modèle 2 — Module de trois semaines 9

6.3 Modèle 3 — Session complète (12 semaines) 10

6.4 Modèle 4 — Projet intégrateur ou séminaire aux cycles supérieurs 11

7 Avant la session : liste de vérification 11

8 Animer les laboratoires 11

9 Enseigner les concepts difficiles 13

10 L'IA générative dans le cours 14

11 Stratégie d'évaluation 16

12 Prestation bilingue et inclusive 16

13 Dépannage 16

14 Soutien, rétroaction et mises à jour 18

1 À propos de ce guide

Ce guide aide les enseignants, les auxiliaires d'enseignement et les coordonnateurs de programme à intégrer CyberRiskGuardian (CRG) dans un cours de gestion des risques en cybersécurité, de gouvernance, d'audit des TI ou de gestion des technologies d'affaires. Il explique ce que la méthode enseigne, quelle version de l'outil utiliser, comment l'intégrer dans un seul atelier ou dans une session complète, comment animer les laboratoires et comment évaluer équitablement le travail lorsque les étudiants sont autorisés à utiliser l'IA générative.

L'ensemble a été conçu à partir du matériel fourni avec CyberRiskGuardian (les spécifications de la méthode, le manuel de gouvernance, les exemples complets MediBec et CanaRetail et les fonctionnalités pédagogiques de l'application de bureau) et à partir du cours de premier cycle de l'auteur sur les risques, la sécurité et l'audit des systèmes d'information, où CRG a été utilisé pour le travail d'équipe d'évaluation des risques.

1.1 Contenu de l'ensemble

Composante	Public	Édition
Guide de l'enseignant (le présent document)	Enseignants, auxiliaires d'enseignement, coordonnateurs	Communautaire (gratuite)
Cahier de laboratoires de l'étudiant — treize laboratoires sur le cas MediBec et un cas d'exercice autonome (CanaRetail), avec les réponses d'autovérification	Étudiants	Communautaire (gratuite)
Trousse d'évaluation — énoncés de travaux, grilles d'évaluation sur 0–10, autovérifications, formulaire d'évaluation par les pairs, déclaration d'utilisation de l'IA	Étudiants et enseignants	Communautaire (gratuite)
Bibliothèque de cas — cinq études de cas fictives avec un guide pour en choisir une	Étudiants et enseignants	Communautaire (gratuite)
Présentation d'introduction — la méthode CRG en un cours, avec des captures d'écran de l'application de bureau 1.9.1 (les écrans de la 1.9.2 ne diffèrent que par le libellé)	Enseignants	Communautaire (gratuite)
Modèle Excel v2-6 — le modèle Excel CyberRiskGuardian vierge (`templates/`)	Étudiants et enseignants	Communautaire (gratuite)
Présentations des chapitres — 21 présentations du manuel, une par chapitre (fichiers joints aux versions GitHub, en anglais)	Enseignants	Communautaire (gratuite)
Édition Éducateur — corrigés des laboratoires, banque de questions de quiz notées, calibrage des grilles d'évaluation et banque de commentaires, notes pédagogiques des cas, cas de l'examen final et son plan, et le guide de ressources de l'enseignant du manuel	Enseignants seulement	Édition éducative (Licence éducative)

Tout le contenu, à l'exception de l'Édition Éducateur, est publié avec l'édition communautaire sous licence CC BY-NC 4.0, en anglais et en français. L'Édition Éducateur est tenue à l'écart du dépôt public afin que les corrigés et le cas d'examen demeurent utiles d'une session à l'autre.

1.2 Qui peut l'utiliser, et quand une licence est nécessaire

- Les **étudiants** peuvent utiliser CyberRiskGuardian et cet ensemble gratuitement pour leurs propres travaux de cours, y compris les travaux remis pour une note.
- Les **enseignants** peuvent consulter, adapter et réutiliser le matériel gratuit à des fins d'enseignement non commerciales, avec attribution.
- Les **collèges, cégeps et universités, en tant qu'établissements,** doivent détenir la **licence éducative** CyberRiskGuardian pour offrir un cours fondé sur CRG. Elle est offerte à un prix considérablement réduit et comprend l'installation, la personnalisation et l'Édition Éducateur.
- Les **organismes sans but lucratif** peuvent utiliser CRG gratuitement pour évaluer leurs propres risques.

Demandes de licence : **sales@cyberriskguardian.ca** · site du produit : **cyberriskguardian.ca**. Le texte juridique de la licence CC BY-NC 4.0 fourni dans le dépôt prévaut en cas de divergence entre ce résumé et la licence. Ceci ne constitue pas un avis juridique.

2 CyberRiskGuardian en une page

CyberRiskGuardian est une méthode d'évaluation des risques en cybersécurité fondée sur des scénarios de risque, appuyée par un assistant d'IA (le plugiciel et le projet Claude), une application de bureau et un modèle Excel. C'est un **outil d'aide à la décision** : il structure l'analyse et l'accélère, tandis que l'analyste demeure responsable de chaque estimation et la direction, de chaque décision relative au risque.

Le déroulement. Contexte organisationnel → joyaux de la couronne (actifs critiques) → appétence pour le risque → 25 à 40 scénarios de risque candidats (20 dans les laboratoires) → les 10 plus importants → six paramètres et le CVSS pour chacun → risque estimé et risque toléré → portefeuille de traitement → risque résiduel par rapport à la tolérance → recommandations, budget et ICR. Le manuel (chapitre 6) numérote ces étapes comme les 19 étapes CRG, suivies du rapport de gestion et d'une revue de qualité indépendante.

Un scénario de risque est une chaîne causale, jamais le nom d'une menace. *Source de menace ou événement → vulnérabilité ou faiblesse → actif ou processus touché → événement de cybersécurité → conséquence organisationnelle.* « Rançongiciel » est une menace; « un affilié d'un groupe de rançongiciel utilise des identifiants VPN volés et l'absence d'authentification multifacteur (MFA) sur l'accès à distance pour chiffrer les serveurs de planification clinique, ce qui interrompt les rendez-vous dans tous les sites pendant plusieurs jours » est un scénario de risque.

Six paramètres, chacun sur une échelle de 0 à 1.

Symbole	Paramètre	Question à laquelle il répond
Pb(A)	Probabilité de présence de la menace	Cette source de menace agira-t-elle contre nous au cours des 12 prochains mois?
Pb(ψ, A)	Probabilité d'exploitation	Si elle agit, réussira-t-elle à exploiter notre faiblesse?
δe(ψ, A)	Dommage estimé	Quelle ampleur de préjudice peut-on raisonnablement prévoir?
δm(ψ,	Dommage maximal	Quelle ampleur de préjudice, au pire plausible?

Symbole	Paramètre	Question à laquelle il répond
A)		
θ(ψ,A)	Résilience organisationnelle	Dans quelle mesure pouvons-nous prévenir, détecter, contenir, intervenir, rétablir et poursuivre nos activités?
μ(E)	Criticité organisationnelle (utilité espérée)	Quelle est l'importance du service touché pour la mission?

Les formules (Guide Excel v1.0c, section 11 — elles font autorité et ne sont jamais modifiées à l'insu de quiconque) :

```
Risque estimé   Re = Pb(A) × Pb(ψ,A) × CVSS × ((δe + δm) / 2) × μ(E) ÷ θ × Facteur
Risque toléré   Rt = Pb(A) × Pb(ψ,A) × CVSS × Appétence × μ(E) ÷ θ × Facteur
Risque atténué     = Re × Réduction de la probabilité × Réduction de l'impact
Risque résiduel    = Re − Risque atténué
Ratio (risque résiduel / risque toléré) = Résiduel ÷ Toléré
```

Un ratio inférieur à 0,90 se lit **sous la tolérance**, de 0,90 à 1,10 **approximativement à la tolérance**, et supérieur à 1,10 **au-dessus de la tolérance**. Le facteur (habituellement 1 000) met les résultats à l'échelle; il ne modifie jamais un ratio.

Trois mentions dans chaque livrable garantissent l'honnêteté de la preuve :

Mention	Signification
Estimation analytique — validation requise	Une valeur estimée par l'analyste (ou par l'IA)
Lacune d'information — validation organisationnelle requise	Un fait que personne n'a fourni
Décision de la direction requise	Un choix que seule la direction peut faire

Ces mentions constituent l'habitude la plus utile qu'enseigne la méthode. Un étudiant qui les utilise correctement a compris la différence entre la preuve, l'inférence et le jugement.

3 Résultats d'apprentissage

CRG soutient des résultats d'apprentissage que la plupart des cours de risque, de sécurité et d'audit comportent déjà. Le tableau les associe aux laboratoires et aux évaluations de cet ensemble. Adaptez la formulation au référentiel de compétences de votre programme.

#	À la fin du cours, les étudiants seront en mesure de…	Laboratoires	Évaluation
RA 1	Décrire le contexte, les processus critiques et les joyaux de la couronne (actifs critiques) d'une organisation à partir des éléments du cas, en distinguant les faits des hypothèses	1	A1 (contexte), examen
RA 2	Estimer et justifier une appétence pour le risque en cybersécurité et expliquer en quoi elle diffère de la tolérance au risque et d'un score de	2	A1, quiz

#	À la fin du cours, les étudiants seront en mesure de...	Laboratoires	Évaluation
	risque		
RA 3	Rédiger des scénarios de risque en cybersécurité plausibles sous forme de chaînes causales complètes et sélectionner un portefeuille de scénarios importants	3	A1 (S1), examen
RA 4	Estimer les six paramètres CRG avec justification, preuve et niveau de confiance, et coter une vulnérabilité représentative avec CVSS v4.0	4, 5	A1
RA 5	Calculer le risque estimé, toléré, atténué et résiduel et interpréter le résultat par rapport à la tolérance	6	A1, quiz
RA 6	Concevoir un portefeuille de traitement rentable, sans doublons, lié à la chaîne causale	7	A1 recommandation
RA 7	Vérifier comment les conclusions changent selon différentes hypothèses	8	A1, examen
RA 8	Définir des indicateurs clés de risque avec responsables, sources et seuils	9	A1, A2
RA 9	Communiquer le risque à la haute direction dans une note de service axée sur la décision	10	A1 note de service, examen
RA 10	Utiliser l'IA générative de façon responsable : vérifier ses résultats, identifier les estimations, protéger les données et en déclarer l'utilisation	Tous	Toutes (critère de professionnalisme)
RA 11	Traduire les résultats de l'évaluation des risques en une politique de sécurité et en un plan d'audit fondé sur les risques	12	A2, A3
RA 12	Lire la posture d'une organisation en matière d'identités, d'accès et de configuration à partir de preuves au niveau des populations, et transformer un constat en élément probant et en proposition de paramètre justifiée	13	A2

4 Choisir un parcours d'outil

La méthode est la même dans chaque parcours; seule l'interface change. Choisissez un parcours par cours et indiquez-le dans le plan de cours, afin que les équipes soient évaluées sur un pied d'égalité.

Parcours	Ce qu'utilisent les étudiants	Forces	Points de vigilance
A. Claude (plu	Le plugiciel gratuit CyberRiskGuardian Core dans Claude Code ou Claude Cowork, ou	Rédaction rapide de scénarios de risque, collecte du contexte sous forme d'entrevue, vérification intégrée des mentions, commandes `/crg-quick-scan` et `/crg-`	Les étudiants doivent vérifier les résultats de l'IA; la politique institutionnelle sur l'IA et les règles de protection

Parcours	Ce qu'utilisent les étudiants	Forces	Points de vigilance
giciel ou projet)	un projet Claude contenant les instructions CRG	`assess`, calculateur vérifié	des données s'appliquent
B. Application de bureau	CyberRiskGuardian Desktop (version courante; 1.9.2 bêta au moment de la rédaction), servie localement dans un navigateur	Tout sur un seul écran; une **carte de prochaine étape** sur la page Processus qui indique toujours quoi faire et où; trois niveaux de détail (Minimal, Standard, Détaillé); une aide reliée au chapitre du manuel de chaque écran; espaces de travail de classe; autovérification du moteur; *Recommencer* pour les cas pédagogiques; MediBec et CanaRetail fournis en anglais et en français; le **Consultant virtuel** (réponses tirées du manuel, de l'ontologie et de l'espace de travail, sur un modèle local par défaut); modules facultatifs **Gestion des identités et des accès (GIA/GAP)** et **Gestion de la configuration**; données de simulation pour des exercices SIEM/SOAR; interface EN/FR; aucune donnée ne quitte l'ordinateur à moins que l'étudiant ne l'envoie	Nécessite Python 3 pour servir le dossier; conserver la même adresse et le même port pour que les espaces de travail soient retrouvés; une seule fenêtre à la fois (une deuxième fenêtre à la même adresse écrase les sauvegardes de la première)
C. Modèle Excel	Le modèle Excel CyberRiskGuardian gratuit (feuille Analyse, S1–S10, M1–M10), dans `templates/`	Formules transparentes, familières aux étudiants en gestion, fonctionne hors ligne	Mode de calcul manuel (appuyer sur F9); saisies validées et colonne de contrôles; CVSS vide et obligatoire; la valeur provisoire d'appétence 0,5 doit être remplacée

Une approche **hybride** fonctionne bien en pratique : les étudiants rédigent le contexte et les scénarios de risque avec Claude (parcours A), puis quantifient et traitent les risques dans l'application de bureau ou le classeur (parcours B ou C), où chaque nombre est recalculé par le moteur vérifié.

4.1 Configuration minimale par parcours

Parcours A — Claude.

```
/plugin install cyberriskguardian --marketplace ITriskMgr/CyberRiskGuardian
/plugin install crg-governance-textbook --marketplace ITriskMgr/CyberRiskGuardian
pip install cvss "mcp>=1.2"
```

Redémarrez Claude et approuvez le serveur `crg-calculator` lorsque vous y êtes invité. Dans claude.ai, les compétences (skills) fonctionnent aussi; les calculs utilisent le script `crg_calc.py` fourni.

Parcours B — Application de bureau. Les étudiants suivent les deux guides de première utilisation publiés avec chaque version, en anglais et en français : **Première installation** (`FIRST-INSTALL.md` dans le ZIP, et un PDF sur la page de la version) et **Première configuration** (`FIRST-TIME-SETUP.md`, et un PDF). En bref : décompressez la version, puis double-cliquez sur `start.command` (macOS, Linux) ou `start.bat` (Windows). L'application doit être servie à l'adresse `http://localhost:8099`; double-cliquer sur `index.html` ne fonctionne pas. Sur la page Processus, une carte facultative, *Configurer l'application pour votre pratique*, propose **Répondre aux questions de configuration** : une question sur l'expérience règle le **niveau de détail** (*Détaillé* convient le mieux à une première évaluation) et les questions sur les modules choisissent les modules facultatifs (les étudiants gardent les valeurs par défaut, sauf si votre cours en utilise un, comme les deux modules du laboratoire 13). Les deux se changent plus tard dans Paramètres → Langue et détail et Paramètres → Modules. Installez-la comme application à partir de Chrome ou d'Edge pour l'utiliser hors ligne.

Parcours C — Excel. Le modèle vierge est fourni gratuitement avec cet ensemble : `templates/CyberRiskGuardian_Excel_Model_Blank_v2-6.xlsx`. Publiez-le sur votre plateforme d'apprentissage. Il suit la procédure en 8 étapes du chapitre 6 du manuel, imprimée dans la feuille Analyse. Rappelez aux étudiants que :

- il s'ouvre en mode de calcul manuel (Formules → Calculer maintenant, F9);
- l'appétence en E14 est une valeur provisoire (0,5) à remplacer par la valeur approuvée ou estimée du cas, strictement entre 0 et 1;
- le facteur en E15 vaut 1 000 et ne change pas;
- les scores CVSS (G3:G12) sont vides au départ et obligatoires, avec le vecteur à côté de chaque score (H3:H12); la colonne de contrôles (AC) signale un vecteur manquant ou mal formé, une saisie invalide et une erreur de réduction;
- dans les feuilles M, les réductions des mesures retenues se combinent selon la règle du produit $1 - \prod(1 - r_i)$, de sorte qu'un bouquet ne dépasse jamais 1;
- le bloc budgétaire (Y14:AC25) compare les dépenses actuelles et le portefeuille recommandé à la cible cohérente avec l'appétence et affiche l'écart et l'appétence implicite;
- les colonnes AD et AE consignent la part de la perte couverte par un transfert et son approbateur, à titre d'information seulement.

4.2 La vérification que chaque étudiant fait en premier

Quel que soit le parcours, la première chose que fait un étudiant est de confirmer que le moteur de calcul concorde avec l'implémentation de référence :

- Application de bureau : le pied de page épinglé du menu latéral doit afficher ✓ **Moteur vérifié**; en pointant dessus, ou dans Aide → À propos et versions, on voit les totaux **84 305 / 41 023**.
- Claude ou ligne de commande : à partir du dossier `crg-quantify/scripts` du plugiciel, `python3 crg_calc.py ../../../evals/_shared/medibec30.json` (dans un clone du dépôt, `examples/medibec/source/medibec30.json` est le même fichier) doit indiquer **total estimated 84,305** et **residual 41,023** (risque estimé total de 84 305 et risque résiduel de 41 023).
- Excel : saisissez l'exemple du chapitre 6 du manuel en S1 (CVSS 9,3, vecteur `CVSS:4.0/AV:L/AC:L/AT:N/PR:N/UI:P/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H`) et confirmez un risque estimé de 3 554,46 et un risque résiduel de 1 937,18 après « Calculer maintenant ».

Si ce n'est pas le cas, rien de ce qui est produit sur cette installation ne doit être considéré comme fiable. Intégrez cette vérification au laboratoire 0 et demandez une capture d'écran.

5 Utiliser le manuel

L'ensemble accompagne le manuel *Introduction à la gouvernance de la cybersécurité* (Léger, 3e éd., v2.51b — la v2.51 corrigée —, octobre 2026), édition française de *Introduction to Cybersecurity Governance for Business Technology Management*. L'édition anglaise est offerte gratuitement sous la forme du plugiciel `crg-governance-textbook` (version 2.1.1); son annexe relie les 21 chapitres aux activités CRG. Les documents français du présent ensemble citent l'édition française et en reprennent les termes. Dans l'application de bureau, l'aide de chaque écran s'ouvre sur un lien **Pour en savoir plus : chapitre n — section** vers le passage du manuel qui l'explique. Les laboratoires s'appuient sur ces chapitres :

Laboratoires et activités	Chapitres du manuel
Laboratoire 0 (vérification du moteur) et laboratoire 1 (contexte, joyaux de la couronne)	Chapitre 6 (déroulement, étapes 1 à 3); chapitre 5 (le contexte d'abord)
Laboratoire 2 (appétence pour le risque)	Chapitre 4 (appétence et tolérance, bandes de tolérance, référence budgétaire)
Laboratoire 3 (candidats, tri, sélection)	Chapitre 5 (25 à 40 candidats, cinq stratégies de génération, douze critères de tri, couverture)
Laboratoires 4 à 8 (paramètres, CVSS v4.0, indices de risque, traitement, sensibilité)	Chapitre 6 (indice de risque, CVSS par équivalence, procédure du classeur, exemple MediBec)
Laboratoire 9 (ICR)	Chapitre 6 (ICR de suivi); chapitre 14 (mesures et configurations de référence)
Laboratoire 10 (note de gestion, budget)	Chapitre 6 (rapport de gestion, calibrage du budget); chapitre 4; chapitre 17 (gouvernance des investissements, assurance comme transfert)
Laboratoire 12 (du risque à la politique et à l'audit)	Chapitre 9 (référentiels de contrôles), chapitre 10 (IAM), chapitre 3 (conformité et assurance)
Laboratoire 13 (posture des identités, des accès et de la configuration)	Chapitre 10 (gestion des identités et des accès privilégiés, auditabilité et preuves); chapitre 14 (configurations de référence, détection et correction des dérives)
Cas d'exercice : CanaRetail (autonome)	Chapitre 6 (l'indice de risque, la procédure du classeur); chapitre 4 (budget cohérent avec l'appétence)

Chaque chapitre se termine par vingt questions à choix multiples; les lettres des réponses figurent en annexe du manuel. Le **guide de ressources de l'enseignant** (justification de chaque réponse et indications de correction des questions à développement) et les 21 présentations des chapitres accompagnent le manuel : les présentations sont des fichiers gratuits joints aux versions du dépôt (voir `education/LISEZMOI.md`), et le guide de ressources de l'enseignant fait partie de l'Édition Éducateur.

6 Modèles d'intégration

Choisissez le modèle qui correspond au temps dont vous disposez. Chaque modèle indique les séances, les laboratoires et une pondération suggérée. Les laboratoires sont décrits dans le Cahier de laboratoires de l'étudiant.

6.1 Modèle 1 — Un atelier (3 heures)

Pour un cours existant qui souhaite une seule introduction pratique.

Heure	Activité
0:00–0:30	Présentation d'introduction (diapositives 1–9) : pourquoi des scénarios de risque, les six paramètres, les mentions
0:30–0:45	Laboratoire 0 : installer ou ouvrir l'outil, vérifier le moteur
0:45–1:30	Laboratoire 3 (version abrégée) : les équipes rédigent trois scénarios de risque sous forme de chaîne causale pour MediBec et critiquent ceux des autres équipes
1:30–1:45	Pause
1:45–2:30	Laboratoires 4 et 6 : quantifier un scénario de risque et calculer son risque; comparer avec l'exemple complet
2:30–3:00	Retour en groupe : pourquoi le verdict par rapport à la tolérance ne dépend que du dommage, du traitement et de l'appétence; ce que la direction déciderait

Évaluation : une réflexion d'une page ou le livrable du laboratoire 6 (réussite/échec).

6.2 Modèle 2 — Module de trois semaines

Pour un cours qui consacre une unité à l'évaluation des risques.

Semaine	Cours	Laboratoires	Livrable
1	Contexte, appétence et scénarios de risque	0, 1, 2, 3	Ensemble de scénarios de risque de l'équipe (20 candidats dans la version de laboratoire, 25 à 40 dans une évaluation complète → 10)
2	Quantification, CVSS et interprétation	4, 5, 6, 8	Portefeuille quantifié avec justification
3	Traitement, ICR et note de service à la direction	7, 9, 10	Note de service d'une page et recommandation de deux pages

Pondération suggérée : 20–30 % de la note du cours, au moyen de la grille d'évaluation A1 de la Trousse d'évaluation.

6.3 Modèle 3 — Session complète (12 semaines)

C'est le modèle utilisé dans le cours de premier cycle de l'auteur. L'évaluation des risques (A1) alimente la politique de sécurité (A2) et le plan d'audit (A3), de sorte que les étudiants suivent une même organisation, du risque à la gouvernance jusqu'à l'assurance.

Semaine	Thème du cours	Activité CRG	Échéance
1	Gouvernance, conformité, le professionnel de la sécurité	Présentation du cours; présentation d'introduction; laboratoire 0	—
2	Sécurité des terminaux et des réseaux	Laboratoire 1 : contexte et joyaux de la couronne (MediBec)	—
3	Gestion des risques et protection des renseignements personnels; réaliser une évaluation des risques	Laboratoires 2, 3 et 4; les équipes reçoivent leur cas	—
4	Paysage des menaces; politiques de sécurité	Laboratoire 5 (CVSS v4.0); les équipes rédigent l'ébauche de leur scénario de risque original S1	—
5	Code malveillant; ingénierie sociale; protection des actifs informationnels	Laboratoire 6; point d'étape avec les équipes sur S1–S10	—
6	Évaluation et tests de sécurité; audits de cybersécurité	Laboratoires 7 et 8	—
7	Cryptographie et ICP	Laboratoire 10 (atelier sur la note de service)	**A1 évaluation des risques**
8	Gestion des identités et des accès; Zero Trust	Laboratoire 9 (ICR); rétroaction sur A1	—
9	Résilience; surveillance et intervention en cas d'incident	Laboratoire 11 (facultatif, application de bureau) : trousse de simulation MediBec	—
10	Sécurité infonuagique, sans fil et mobile	Laboratoire 12, partie 1 : du risque au plan d'audit	—
11	Criminalistique numérique; normes et certification	Laboratoire 12, partie 2 : du risque à la politique de gestion des identités et des accès (IAM); laboratoire 13 : posture des identités, des accès et de la configuration (preuves pour l'A2)	**A3 plan d'audit** (individuel)
12	Sécurité des applications; révision	Préparation à l'examen; banque de questions de quiz (Édition Éducateur)	**A2 politique IAM**

Pondérations suggérées, comme dans le cours de premier cycle de l'auteur : A1 20 % (équipe), A2 10 % (équipe), A3 10 % (individuel), examen final 40 % (incluant une dissertation sur une étude de cas), quiz et laboratoires 20 %.

6.4 Modèle 4 — Projet intégrateur ou séminaire aux cycles supérieurs

Les étudiants travaillent sur un cas plus riche (CNIC ou ACRB) ou, avec l'autorisation écrite de l'organisation et les précautions de protection des données de la section 9, sur un véritable organisme sans but lucratif. Utilisez la procédure complète de sélection des scénarios de risque (sections A à E : contexte, candidats, présélection, portefeuille final, revue de qualité), l'analyse de sensibilité et le calibrage du budget. Exigez une soutenance orale du portefeuille devant un jury jouant le rôle du conseil d'administration.

7 Avant la session : liste de vérification

1. **Choisissez le parcours** (section 4) et testez-le sur les ordinateurs qu'utiliseront les étudiants, y compris ceux des laboratoires informatiques.
2. **Choisissez les cas** (Bibliothèque de cas). Utilisez MediBec pour les laboratoires, car son exemple complet est public et les étudiants peuvent s'y comparer. La solution de CanaRetail est aussi publique (dans l'application de bureau) : gardez-le pour l'exercice autonome. Attribuez Chez Pierre, ACRB ou CNIC à chaque équipe pour le travail noté, et faites une rotation des cas d'une session à l'autre.
3. **Préparez un espace de travail de classe** (parcours application de bureau) : Organisation → Espaces de travail → Nouvel espace de travail, *Partir de* **Exemple pédagogique : MediBec — soins de santé privés** (anglais ou français), type *Cas d'affaires pour la classe*, cochez *Cas pédagogique utilisé à des fins de formation*. Lorsqu'il est prêt à être distribué, Organisation → Réinitialiser les données → *Pour l'enseignant* → **Définir l'état actuel comme point de départ**, afin que les équipes puissent recommencer.
4. **Déterminez les étapes que les étudiants refont** après *Recommencer* (par défaut, les étapes 2 et 3 : contexte et joyaux de la couronne).
5. **Décidez des modules facultatifs.** Pour le laboratoire 13, les étudiants activent *Gestion des identités et des accès (GIA/GAP)* et *Gestion de la configuration* dans Paramètres → Modules. Les espaces de travail MediBec et CanaRetail contiennent déjà des registres d'exemple fictifs pour les deux modules; rien dans ces registres ne modifie un nombre de risque.
6. **Chargez la trousse de simulation** si vous prévoyez le laboratoire 11 (Paramètres → Données de simulation → Trousse MediBec). Le rapport d'importation doit indiquer 40 alertes, 13 règles, 15 indicateurs, 4 dossiers et une autoapprobation refusée (APR-MB-04).
7. **Inscrivez vos règles sur l'IA dans le plan de cours** (section 9), y compris si le Consultant virtuel est permis pour chaque travail, et joignez le modèle de déclaration d'utilisation de l'IA de la Trousse d'évaluation.
8. **Publiez la Trousse d'évaluation** avec vos dates de remise, limites de pages et pondérations.
9. **Vérifiez les règles de protection des données de l'établissement** relatives aux outils d'IA et décidez quels fournisseurs d'IA les étudiants peuvent utiliser. Dans l'application de bureau, chaque fonction d'IA peut être acheminée vers un modèle local ou désactivée dans Paramètres → IA — locale et distante.

8 Animer les laboratoires

Chaque laboratoire du cahier présente ses objectifs, sa durée, ses intrants, ses étapes, son livrable et trois questions d'autovérification. Les notes ci-dessous s'adressent à la personne qui anime la séance.

Laboratoire	Durée	Points de vigilance	Une question qui débloque le groupe
0. Prise en main	30 min	Étudiants qui ouvrent `index.html` directement (pied de page bloqué sur *chargement du moteur…*); espaces de travail perdus en raison de ports différents; deux fenêtres ouvertes à la même adresse	« Pourquoi ne devriez-vous vous fier à aucun nombre tant que le pied de page n'indique pas *Moteur vérifié*? »
1. Contexte et joyaux de la couronne	60 min	Copier le texte du cas au lieu de l'analyser; inventer des faits	« Lequel de ces faits changerait votre classement des risques s'il était faux? »
2. Appétence pour le risque	45 min	Confondre l'appétence (attitude de 0 à 1) avec un score de risque; ignorer la valeur indiquée dans le cas	« MediBec indique 0,40. Pourquoi un analyste pourrait-il proposer 0,30? »
3. Scénarios de risque	90 min	Des noms de menaces (« hameçonnage ») au lieu de chaînes causales; dix variantes d'une même technique	« Quelle étape de votre chaîne un contrôle interromprait-il? »
4. Quantification	75 min	Fusionner Pb(A) et Pb(ψ,A); δe supérieur à δm; θ fixé à zéro; des nombres sans justification	« De quelles deux valeurs êtes-vous le moins sûr, et quelle preuve permettrait de trancher? »
5. CVSS v4.0	60 min	Coter l'ensemble du scénario de risque au lieu d'une seule faiblesse; estimer un score à l'œil	« Quelle vulnérabilité, exactement, avez-vous cotée? »
6. Calcul	45 min	Lire le risque estimé comme un montant en dollars; ignorer le risque toléré	« Pourquoi un scénario rare obtient-il le même verdict qu'un scénario fréquent à dommage égal? »
7. Traitement	90 min	« Accumulation de contrôles »; compter deux fois un contrôle partagé; des réductions dont la somme dépasse 1	« Qu'apporte ce contrôle que l'organisation n'a pas déjà? »
8. Sensibilité	45 min	Considérer le cas central comme la vérité	« Quelle décision change entre le cas optimiste et le cas pessimiste? »

Laboratoire	Durée	Points de vigilance	Une question qui débloque le groupe
9. ICR	45 min	Des indicateurs sans responsable, sans source ou sans seuils	« Qui mesurera cet indicateur le premier du mois, et à partir de quel système? »
10. Note de service	60 min	Reprendre les tableaux; enfouir la décision	« Qu'attendez-vous du chef de la direction financière lundi? »
11. Opérations de sécurité (facultatif)	120 min	Considérer une alerte comme un incident; utiliser le niveau de confiance d'une source comme une probabilité	« Qui a confirmé cet incident, et quand? »
12. Du risque à la politique et à l'audit	90 min	Des politiques remplies de valeurs techniques; des plans d'audit qui vérifient seulement l'existence d'une politique; avec l'étape facultative du rédacteur, remettre le brouillon généré comme réponse	« Comment un auditeur prouverait-il que ce contrôle fonctionne sur une période donnée? » · « Pourquoi le rédacteur a-t-il laissé cette décision en espace réservé au lieu de décider? »
13. Posture des identités, des accès et de la configuration	90 min	Lire un décompte vide comme un zéro; lire l'indication de sens d'un constat comme une valeur; accepter une proposition dans l'espace de travail utilisé pour les autres laboratoires; nommer des personnes dans les libellés des registres	« Lequel de ces décomptes demanderiez-vous d'abord à l'équipe GIA de confirmer, et pourquoi? »

9 Enseigner les concepts difficiles

L'expérience avec la méthode montre qu'une poignée d'idées causent l'essentiel de la confusion. Enseignez-les explicitement.

L'appétence n'est pas la tolérance, et ni l'une ni l'autre n'est un score. L'appétence pour le risque (0–1) exprime le niveau de risque que la direction est prête à assumer; le risque toléré est l'appétence appliquée à un scénario de risque précis au moyen de la formule. Le plugiciel du manuel répond à la question « Quelle est la différence entre l'appétence pour le risque et la tolérance au risque? » en citant un chapitre — une bonne mise en train pour le laboratoire 2.

La présence de la menace et l'exploitation sont deux probabilités différentes. Pb(A) demande si la source de menace agira; Pb(ψ,A) demande si elle réussira à exploiter cette faiblesse compte tenu des contrôles existants. Les fusionner revient à compter deux fois.

Le CVSS cote une vulnérabilité, pas un scénario de risque. Le score de base CVSS v4.0 mesure la gravité technique d'une faiblesse définie. Pour les scénarios d'hameçonnage, de menace interne, de processus, physiques, de tiers ou de gouvernance, les étudiants cotent une faiblesse *représentative* **par équivalence** (chapitre 6 du manuel) et la qualifient d'*applicabilité limitée*. Le CVSS demeure un multiplicateur obligatoire : un score est toujours requis; un document malveillant reçu par courriel est coté AV:L. Un score CVSS élevé ne signifie jamais le risque d'affaires le plus élevé.

Le verdict par rapport à la tolérance ne dépend que du dommage, du traitement et de l'appétence. Le rapport Résiduel ÷ Toléré se simplifie en ((δe + δm)/2) × (1 − P × Q) ÷ Appétence. Les probabilités, le CVSS, la résilience et la criticité s'annulent : ils déterminent l'*ampleur* du risque (le classement), mais pas le *verdict*. C'est un résultat frappant pour les étudiants. Servez-vous-en pour montrer pourquoi le ratio doit toujours être lu conjointement avec le risque estimé.

Avant le traitement, presque tout est au-dessus de la tolérance. Le ratio avant traitement correspond au dommage moyen ÷ l'appétence. Avec une appétence de 0,30, tout scénario de risque dont le dommage moyen dépasse 0,33 commence au-dessus de la tolérance. Les étudiants qui s'attendent à un portrait mitigé avant le traitement sont généralement surpris.

L'atténuation est multiplicative. Une réduction de 80 % de la probabilité et une réduction de 80 % de l'impact éliminent 64 % du risque, et non 80 %. Pour que le résiduel ne dépasse pas le toléré (ratio ≤ 1,0), il faut que P × Q ≥ 1 − appétence ÷ dommage moyen; pour être **sous la tolérance** (ratio < 0,90), il faut que P × Q > 1 − 0,90 × appétence ÷ dommage moyen. Un ensemble de mesures qui ne réduit que la probabilité, ou que l'impact, n'atténue rien selon la convention du classeur.

Les contrôles partagés sont comptés une seule fois. Lorsqu'une initiative sert plusieurs scénarios de risque, son coût est réparti entre eux (une répartition égale est une valeur par défaut acceptable) et le total du portefeuille provient des initiatives, et non de la somme des affectations par scénario.

Les registres de posture sont des éléments probants, pas des risques. Les registres de la Gestion des identités et des accès et de la Gestion de la configuration contiennent des décomptes par population, jamais de noms. Leurs indicateurs (CRG-17 à CRG-25) sont des ICR *mesurés*, et non des indices de risque. Un constat donne un sens (Pb(ψ,A) ↑ ou θ ↓), jamais une valeur : l'analyste saisit la nouvelle valeur, l'application montre le ratio avant et après, et l'accepter est un acte distinct, journalisé. Servez-vous du laboratoire 13 pour montrer comment une preuve entre dans une estimation sans que personne « laisse l'outil décider ».

Deux perspectives peuvent diverger. Un score normalisé simple (menace × exposition × impact × (1 − maturité des contrôles)) assorti de seuils de remontée peut situer un risque traité à l'intérieur des limites d'autorité, alors que le ratio CRG le signale au-dessus de la tolérance. Demandez aux étudiants d'indiquer à quelle méthode un seuil de gouvernance est rattaché.

10 L'IA générative dans le cours

CyberRiskGuardian est lui-même un outil assisté par l'IA; le cours doit donc adopter une position claire sur l'IA. La position ci-dessous est celle utilisée dans le cours de premier cycle de l'auteur; adaptez-la à la politique de votre établissement.

Permise pour les travaux, avec une déclaration explicite (modèle dans la Trousse d'évaluation). Les étudiants sont responsables de tout ce qu'ils remettent, y compris de tout ce qu'une IA a produit.

Interdite pendant l'examen. Les étudiants peuvent préparer du matériel avec l'IA avant l'examen (par exemple, des scénarios de risque remis avec l'examen) s'ils le déclarent.

Ce que l'IA peut faire : rédiger des ébauches de scénarios de risque, proposer des valeurs de paramètres avec justification, critiquer des estimations, suggérer des contrôles, corriger la grammaire, résumer des sources.

Ce que l'IA ne peut pas faire : énoncer des faits sur le cas que le cas ne contient pas, produire un nombre final que l'étudiant n'a pas recalculé avec le moteur vérifié, inventer des normes, des identifiants de contrôles, des obligations légales, des statistiques ou des sources.

La vérification est la compétence évaluée. Les outils d'IA inventent des identifiants de contrôles, des vecteurs CVSS et des lois avec beaucoup d'assurance. Évaluez la vérification, pas la prose : une source fabriquée ou introuvable constitue à la fois un problème de preuve et un enjeu d'intégrité académique.

Protection des données. Les étudiants ne collent pas de matériel confidentiel dans un service d'IA externe sans autorisation. Les cas fictifs ne posent pas de risque; les organisations réelles, si, à moins que l'organisation n'ait donné son accord par écrit et que les règles de l'établissement le permettent. Dans l'application de bureau, les requêtes d'IA affichent le contenu exact avant tout envoi, peuvent être anonymisées et peuvent être acheminées vers un modèle local.

Le Consultant virtuel : décidez pour chaque travail. L'application de bureau comprend un Consultant virtuel (bouton **Consultant** de la barre supérieure, ou Outils → Consultant virtuel). Il répond à partir de passages récupérés sur l'ordinateur de l'étudiant — le manuel, l'ontologie CRGO, les documents et les enregistrements de l'espace de travail — et les sépare des connaissances générales du modèle, qu'il marque *Estimation analytique — validation requise*. Il n'écrit rien dans l'évaluation et retire tout chiffre de risque que le moteur n'a pas calculé. Comme c'est un outil d'IA, **indiquez dans l'énoncé de chaque travail s'il est permis** (les énoncés A1 à A3 de la Trousse d'évaluation prévoient une ligne à cet effet) :

- **Permis :** les étudiants le déclarent comme tout autre outil dans la déclaration d'utilisation de l'IA et joignent les conversations sur lesquelles ils se sont appuyés (Outils → Consultant virtuel → *Historique* → *Exporter en Markdown*). Une conversation peut aussi être citée dans le registre des éléments probants (*Citer comme élément probant*), où elle est classée comme hypothèse.
- **Non permis :** les étudiants le désactivent dans Paramètres → IA — locale et distante, en réglant les lignes *Consultant virtuel* et *Consultant virtuel — critique des paramètres* à **Désactivé**. Les étudiants travaillent sur leur propre ordinateur, ce qui empêche de l'imposer techniquement. Traitez-le comme une règle d'intégrité académique et consultez l'exportation de l'espace de travail : chaque appel à l'IA est consigné dans le journal d'IA de l'espace de travail, qu'affiche Outils → Consultant virtuel → *Journal des décisions*.

Par défaut, le consultant fonctionne sur un **modèle local** : aucun texte ne quitte l'ordinateur, à moins que l'étudiant ne l'achemine vers un fournisseur distant.

Les mentions font le pont. Demandez aux étudiants de conserver les trois mentions dans chaque livrable. Un livrable sans mention est un signal d'alarme indiquant que des résultats de l'IA ont été pris pour des faits. Le plugiciel Claude comprend une vérification des mentions (`check_labels.py`) qui dresse la liste des mentions manquantes.

11 Stratégie d'évaluation

La Trousse d'évaluation contient :

- l'**échelle de 0 à 10** et la façon dont les notes par critère se combinent en une note de travail;
- des **énoncés et des grilles d'évaluation** pour l'évaluation des risques (A1), la politique de sécurité IAM (A2) et le plan d'audit fondé sur les risques (A3), ainsi que quatre formats plus courts (portfolio de laboratoires, travail individuel sur un scénario de risque, défi d'analyse rapide en classe, dissertation d'examen);
- des **listes d'autovérification**, un **formulaire d'évaluation par les pairs** pour les travaux d'équipe et la **déclaration d'utilisation de l'IA**.

L'Édition Éducateur ajoute les corrigés des laboratoires, une banque de questions de quiz notées avec réponses, des exemples de calibrage des grilles d'évaluation, une banque de commentaires de rétroaction, des notes pédagogiques pour chaque cas, le cas de l'examen final et son plan, ainsi que le guide de ressources de l'enseignant du manuel.

Protéger l'intégrité de l'évaluation.

- Utilisez MediBec et CanaRetail uniquement pour la pratique. Leurs réponses complètes sont publiques : celle de MediBec dans l'exemple complet publié, celle de CanaRetail dans l'application de bureau (son module D : les neuf scénarios fournis et un scénario original, quantifiés et traités).
- Faites une rotation des autres cas (Chez Pierre, ACRB, CNIC) d'une session à l'autre et d'un groupe-cours à l'autre pour les travaux notés. L'Édition Éducateur contient un sixième cas, réservé à l'examen.
- Exigez que le scénario de risque original S1 soit distinct de tous les scénarios fournis dans le cas et dans les guides.
- Exigez l'exportation du classeur ou de l'espace de travail avec la note de service, et vérifiez que les nombres concordent. Une discordance entre les fichiers est le signe le plus courant de résultats d'IA non vérifiés.
- Demandez une brève présentation orale des paramètres d'un scénario de risque par un membre de l'équipe choisi au hasard.

12 Prestation bilingue et inclusive

L'application de bureau fait basculer toute son interface entre l'anglais et le français (EN/FR dans la barre supérieure) tout en laissant les données du cas dans leur langue d'origine. Ses termes français suivent l'édition française du manuel (*appétence pour le risque*, *joyaux de la couronne*, *registre des éléments probants*, *ratio risque résiduel / risque toléré*), et MediBec et CanaRetail sont fournis dans les deux langues. Tout le matériel gratuit de cet ensemble existe dans les deux langues. Un cas en français demeure en français dans une interface anglaise; les équipes peuvent rédiger dans l'une ou l'autre langue si votre établissement le permet.

Pour l'accessibilité, les laboratoires peuvent être réalisés entièrement au clavier dans l'application de bureau et dans Excel; la présentation utilise un texte à contraste élevé; chaque figure du cahier est aussi fournie sous forme de texte. Accordez du temps supplémentaire pour les laboratoires 3 et 10, qui exigent beaucoup de rédaction.

13 Dépannage

Symptôme	Cause	Solution
Pied de page bloqué sur *chargement du moteur…*	L'application a été ouverte comme un fichier	La démarrer avec `start.command` ou `start.bat`; ouvrir `http://localhost:8099`

Symptôme	Cause	Solution
Les espaces de travail d'un étudiant ont disparu	Adresse, port ou navigateur différent	Utiliser la même adresse et le même port; importer la dernière exportation de l'espace de travail
Excel affiche les formules, mais d'anciens nombres	Mode de calcul manuel	Formules → Calculer maintenant (F9)
« θ required » ou « CVSS required » dans la feuille Analyse (colonnes M et N)	θ laissé vide ou à zéro dans la feuille S, ou score CVSS non saisi	Saisir θ supérieur à zéro (jusqu'à 1) et le score CVSS v4.0 avec son vecteur
« Appetite required » dans la colonne N	L'appétence en E14 n'est pas strictement entre 0 et 1	Saisir l'appétence approuvée ou estimée
Le ratio d'un scénario de risque n'a pas changé après l'ajout de mesures	Mesures non appliquées, ou une seule dimension réduite	Appliquer l'ensemble de mesures; ajouter une mesure pour l'autre dimension
Verdict « Review M… » ou avertissement sous la ligne TOTAL d'une feuille M	Un coefficient (colonne K ou L) est hors de 0 à 1	Corriger le coefficient; les réductions combinées suivent la règle du produit et ne dépassent jamais 1
L'IA propose une loi que le cas ne mentionne pas	Invention de l'IA	La retirer; ne citer que les obligations que le cas mentionne ou qu'une source primaire confirme
La trousse de simulation ne s'importe pas	L'espace de travail n'est pas une copie de MediBec	Importer dans l'exemple MediBec ou dans une copie de celui-ci
Le pied de page affiche ✕ *Échec de la vérification du moteur* (bandeau *Le moteur ne reproduit pas la référence MediBec*)	Le moteur ne concorde pas avec la référence	Arrêter et restaurer une copie intacte de l'application
L'écran Gestion des identités et des accès ou Gestion de la configuration indique que le module est désactivé	Les modules facultatifs sont désactivés par défaut	Paramètres → Modules, groupe Gouvernance
Un deuxième espace de travail MediBec apparaît après la restauration d'une sauvegarde ou l'importation d'un fichier d'espace de travail (1.9.1)	Le cas fourni n'était reconnu que par son identifiant	Corrigé dans Desktop 1.9.2 (la restauration et l'importation reconnaissent le cas fourni). En 1.9.1, supprimer la copie en trop dans Organisation → Espaces de travail

Corrigé dans Desktop 1.9.2. Les problèmes ci-dessous ont été rencontrés dans les laboratoires avec Desktop 1.9.1 et sont corrigés en 1.9.2; la ligne indique ce que les étudiants qui utilisent encore la 1.9.1 verront et quoi faire.

Problème et laboratoires (Desktop 1.9.1)	En 1.9.1	En 1.9.2
Laboratoire 1 — L'extraction par règles	Décocher les quatre valeurs et	Corrigé : l'extraction inscrit le

Problème et laboratoires (Desktop 1.9.1)	En 1.9.1	En 1.9.2
seulement inscrivait `[object Object]` dans Nom, Taille, Région et Contexte, avec l'étiquette INFERENCE et la case cochée (no 18)	les saisir à partir du cas	texte trouvé
Laboratoire 3 — La promotion d'un candidat depuis le tri perdait ses paramètres, ses liens et sa chaîne causale (no 20)	Ressaisir les six paramètres, les techniques et la chaîne sur le scénario promu	Corrigé : le scénario promu conserve tout
Laboratoire 5 — Un score CVSS enregistré pouvait contredire son vecteur (no 21)	Recalculer le score à partir du vecteur dans l'éditeur avant de lire le risque	Corrigé : le vecteur l'emporte et un score discordant est signalé
Laboratoires 10 et 11 — QC-02 échouait pour toute recommandation approuvée dans l'interface, et un approbateur vide était accepté (no 22)	Ignorer l'échec de QC-02 pour les approbations faites dans l'interface; toujours nommer l'approbateur	Corrigé : QC-02 lit les approbations de l'interface; aucune approbation sans personne nommée
Tous les laboratoires — Deux fenêtres ouvertes à la même adresse perdaient du travail sans avertissement (no 2)	Une seule fenêtre (laboratoire 0)	Corrigé : la deuxième fenêtre est avertie et en lecture seule
Tous les laboratoires — La restauration et l'importation créaient un espace de travail MediBec en double (nos 4 et 5)	Supprimer la copie en trop	Corrigé
Laboratoire 0 — Le laboratoire 0 [A] pointait `crg_calc.py` vers un `medibec30.json` absent du dossier des scripts	Utiliser le chemin indiqué au laboratoire 0 (`../../../evals/_shared/medibec30.json`)	Documentation corrigée dans cet ensemble (2.1.2)

14 Soutien, rétroaction et mises à jour

- Dépôt : **github.com/ITriskMgr/CyberRiskGuardian** (édition communautaire, CC BY-NC 4.0)
- Site du produit et licence éducative : **cyberriskguardian.ca · sales@cyberriskguardian.ca**
- Application de bureau : le bouton **Aide** de la barre supérieure ouvre *Aide sur cet écran*, *Pas à pas*, le *Guide de l'utilisateur* (anglais et français) et *À propos et versions*; les guides de première installation et de première configuration sont sur la page de chaque version

Signalez les erreurs dans cet ensemble au moyen du système de suivi des problèmes (issues) du dépôt, en précisant le document, la section et la version linguistique. Les suggestions d'amélioration des enseignants qui ont enseigné avec CRG sont particulièrement bienvenues.

© 2026 Marc-André Léger. Matériel communautaire sous licence CC BY-NC 4.0. Les cas sont fictifs; toute ressemblance avec des organisations réelles est fortuite. CyberRiskGuardian est un outil d'aide à la décision : les estimations sont des hypothèses analytiques initiales, et les décisions relatives au risque demeurent la responsabilité de la direction.